

Smart cards in electronic commerce

N T Trask and M V Meyerstein

Smart cards can be used in electronic commerce for providing personal security, stored value and mobility. This paper explores the areas where smart cards are becoming a critical enabler for electronic commerce, and also discusses the short-term barriers to the widespread adoption of smart cards. The important influences in terms of standards, working groups and the actions of major players in the smart card arena are also highlighted.

1. Introduction

Magnetic stripe cards have widespread acceptance in today's society, but smart cards, although commonplace in Europe, Latin America and some Asian countries, are still scarce in the USA. Smart card technology has been around for nearly twenty years, but for a long time it has been hard for companies to justify issuing smart cards instead of cheaper magnetic stripe cards. Times are changing, however. Today, smart cards are well established in applications such as telephone call payment, satellite television access and mobile phone access and are now moving into mainstream financial applications. The motivation for this is the improved security and functionality that smart cards can offer. Smart cards have physical tamper-resistant properties, plus secure storage and processing capabilities. They have evolved much in twenty years, from providing simple memory functions through to the sophisticated microcomputer controlled functions seen today.

Can smart cards embrace all these changes in technology and play a leading role in promoting electronic commerce? This paper looks at the barriers to smart card adoption and new developments such as PC/SC and Smart Cards for Windows, it considers the new virtual machine cards such as Multos and Java Card, and, finally, examines the roles smart cards have to play in electronic commerce (eCommerce), considering cards as trusted hardware stores for low-value payments and trusted hardware tokens for trust services.

2. What is a smart card?

Smart cards are credit card-sized plastic cards that house an embedded integrated circuit. Features such as card size, contact layout and electrical characteristics have been defined by ISO (International Standards Organisation) standard 7816 [1]. At the functional level, smart cards can be categorised as either memory cards or microprocessor

cards. Memory cards, such as disposable pre-paid payphone cards or loyalty card, are the most basic and cheapest form of smart card. They contain a small amount of memory in the form of ROM (read only memory) and EEPROM (electrically erasable programmable read only memory). The capacity may only be a few tens of bytes, but the 'non-volatile' nature of the memory enables the storage of simple data, such as decrementing value counters, which is retained after the electrical power supply provided by the terminal is removed (smart cards do not have their own power supply).

Microprocessor cards (such as in Fig 1) are more advanced than simple memory cards in that they contain a microprocessor CPU (central processing unit) and RAM (random access memory) in addition to ROM and EEPROM. The ROM contains the card's operating system and factory-loaded applications. Smart card operating systems tend to be proprietary and there is as yet no widely accepted standard operating system, although Multos and Smart Cards for Windows will soon be vying for that title. The process of manufacturing a chip involves building up the circuitry in layers using 'masks' which selectively expose different parts of the silicon. Any information that has to be placed into ROM is included in this masking process (hence data or applications being referred to as 'masked' into ROM). This has the effect that the ROM contents cannot be changed after manufacture, making designing smart cards a 'black art' and very time consuming. The RAM is used as a small working memory during operations. The EEPROM is again used for non-volatile data storage and, more recently, for application storage as well. It is typically a little larger than for memory cards at around 8 kilobytes presently. This is still very small compared to the capacity of other storage media around today such as hard drives and CD-ROMs, but EEPROM size is steadily increasing as technology advances. EEPROM can be written to as defined by access control restrictions in force on the smart card.

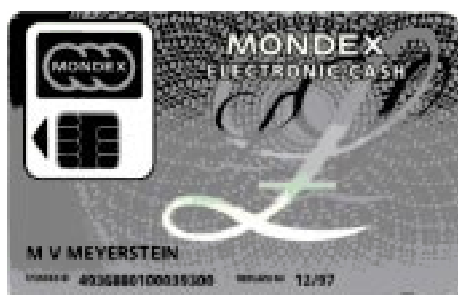


Fig 1 A microprocessor smart card used as a Mondex electronic purse.

Recent developments in smart card technology mean that some microprocessor cards now also contain 'co-processors' dedicated to computationally intensive mathematical operations, such as those used in cryptography. These co-processors, which are also embedded within the chips, speed up the execution of complex calculations. Their advantage will be seen when the use of smart cards for generating digital signatures is discussed later in this paper.

For a number of applications, the most appealing property of a smart card is its supposedly secure, tamperproof nature. The Sky satellite television access cards' security measures have repeatedly been put to the test, inducing a competitive exchange of measures and countermeasures. It is accepted that weaknesses will always be exploited; it is just a case of whether the benefits of breaking a system outweigh the costs involved. Physical attacks against smart cards tend to involve either reverse engineering the silicon circuit to obtain a circuit diagram of the chip or discovering the memory contents by exploiting weaknesses in the chip or firmware design. Manufacturers have to match the countermeasures incorporated on the card against the level of perceived risk. Generally, the policy adopted is one of 'strength in depth'; the physical mechanisms being just one part of smart card security.

3. Card technology — breaking down the barriers

Smart cards seem to be a very useful piece of technology with plenty of potential applications in electronic commerce, but why are they not more commonplace today in that field? For a long time, they have been deemed a 'technology waiting for a problem'. This section considers how some of the fundamental barriers to smart card adoption in eCommerce are currently being addressed. This includes obstacles such as the proprietary nature of smart cards, with cards and readers from different manufacturers tending to suffer from interoperability problems, plus the inflexible nature of cards due to the traditional and time-consuming methods of developing applications for embedding in ROM.

3.1 Towards standardisation

Although ISO 7816 is the fundamental standard for smart cards, it tends to focus mainly on interoperability at the physical, electrical, and data-link protocol levels. Part 4 also defines a standardised logical structure and a small set of commands, but this was adopted by ISO only relatively recently. This has meant that the smart card market has evolved on a largely proprietary basis. With no widely accepted standard smart card operating system, card manufacturers have tended to develop their own unique operating systems, specific to the particular chip hardware. Card applications are then specific to a particular operating system embedded in the chip. Thus, even in schemes like GSM, where cards from different suppliers are interchangeable, the firmware in them is proprietary and non-portable. Smart cards have tended to hold only one application per card, hence users have had to carry several cards to meet their needs, typically from different manufacturers. The fact that end users need an extra piece of hardware, the smart card reader, is one obstacle; requiring them to use more than one manufacturer's reader, as might be the case, is another. The stage needs to be reached where desktop computers are either supplied with or can be fitted with industry-standard smart card readers in which smart cards for a variety of different applications can be used interchangeably.

In 1996, Europay, MasterCard, and Visa (EMV) defined a specification that extended ISO 7816 with the addition of data types and encoding rules for use by the financial services industry [2]. The European telecommunications industry also embraced the ISO 7816 standards for their global system for mobile communications (GSM) smart card specification to enable identification and authentication of mobile phone users [3]. For PC-based smart card applications, further (*de facto*) standards have emerged to address the fact that there was no standard way for PCs to talk to smart card readers, with users being locked into proprietary solutions where a particular manufacturer's card could only be used with that manufacturer's reader.

The PC/SC (Personal Computer/Smart Card) work group [4] was formed in May 1996, backed by some major players in the PC and smart card markets such as Microsoft, HP, IBM, Sun, Gemplus and Schlumberger. It was created to develop open specifications for a standard model to interface smart card readers and cards with PCs. The PC/SC specifications are based on the ISO 7816 standards and are compatible with both the EMV and GSM industry-specific specifications. They provide a layered model, allowing smart card-aware applications to talk to the smart card in a transparent manner, in much the same way as applications today talk to other peripherals such as printers. At the topmost level in the model, as depicted in Fig 2, developers can write smart card-aware applications in a device (card reader) independent manner. Below this, service providers

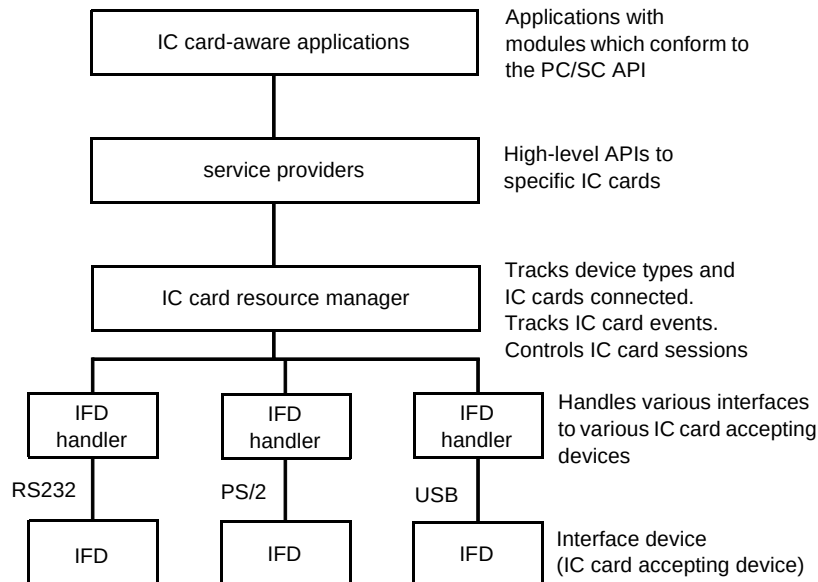


Fig 2 The PC/SC layered model.

written by the smart card manufacturers provide high-level APIs (application programming interfaces) for specific card functions. At the lowest level, and transparent to anything above it, manufacturers provide PC/SC compatible smart card readers and device drivers for the particular Windows platform.

The PC/SC model for how readers and cards interface with the PC should help to enforce interoperability among cards and readers from different manufacturers. There are already a number of PC/SC compatible readers on the market today, as well as various PC applications dependent on PC/SC. HP already has a commitment to provide PC/SC card readers on its Vectra series and Compaq has made a similar announcement for some of its 1999 product range. The latter is said to have been influenced by the imminent arrival of Microsoft's Smart Cards for Windows, which has the power to put a smart card in the hands of every user of any Windows operating system.

PC/SC is one of a series of recent moves designed to simplify the development of smart card applications for the desktop. The ease with which smart cards can now be integrated into Windows applications has been demonstrated by Microsoft. Their Internet Explorer 4.0 Web browser and Outlook 98 and Outlook Express 4.0 e-mail packages are all smart card compatible, enabling client authentication and secure e-mail through the use of digital signatures.

Microsoft applications rely on PC/SC and their own interface for cryptographic operations, the CryptoAPI [5]. The cryptographic services of a smart card are exposed by a cryptographic service provider (CSP) written by the smart card manufacturer. Any Windows application requiring a cryptographic service asks the CryptoAPI to provide it, which in turn communicates with the installed CSPs. A

smart card CSP might use an existing software CSP (such as the Microsoft Base Provider) to perform all public and symmetric key operations and use the smart card itself to perform all private key operations. However, this is not the only approach. Netscape Communicator 4.0, like some other packages, supports RSA Laboratories' Public Key Cryptography Standard (PKCS) #11, which specifies an API called 'Cryptoki' to devices that hold cryptographic information and perform cryptographic functions, such as smart cards [6]. Clearly the two leading producers of Web browser software adopting differing standards is a problem, leading smart card manufacturers to produce two variants of their browser integrated products.

Smart cards are very much in Microsoft's plans for the Windows platform and are likely to be an integral part of NT 5.0, now known as Windows 2000, for operations such as network log-on. To advance this, Microsoft announced their own operating system for cards, 'Smart Cards for Windows', in October 1998 [7]. Designed with security solutions, loyalty cards and electronic purses in mind, it is expected to allow applications to be developed in programming languages such as Visual Basic and Visual C++. The success of Smart Cards for Windows remains to be seen; it could take several years to reach maturity, but is certainly a significant announcement.

3.2 A greater flexibility

Due to the physical size and cost restrictions placed on current smart card microprocessors, having very small memories for example, applications for smart cards have, up until recently, been developed solely in machine language by a small group of experts using very low-level tools. The very fact that applications have historically been embedded into ROM at the time of manufacture means that the application software has to be fully developed and tested

before the smart card chip is manufactured, and cannot be upgraded, corrected or removed afterwards, except by re-issuing a new card. This process is time consuming because of the great amount of careful planning and implementation that is required. The development of smart card applications is therefore slow, taking many months to proceed from concept to reality. This is a great contrast to application development on computers. Computers tend to have a small number of standard operating systems, and software is usually stored on media that can be changed. The benefits of embedding smart card applications in ROM are of security (the software is more resistant to alteration and corruption by an attacker), and of real estate on the chip (ROM uses less space per bit than other memory types).

Two interesting new smart card technologies that address the issue of lengthy development times for new applications are Java Card (which is an API) and Multos (which is an operating system and API).

- Java Card

A Java Card is a smart card capable of running programs written in a much-reduced version of Sun's Java programming language. It is a specialised implementation since smart cards impose many constraints, such as the use of 8-bit integers instead of the 32-bits normally required. The Virtual Machine (VM) translates Java byte code into card processor specific instructions, language specification and core packages, all of which have to be made more compact for smart cards.

The Java Card API [8], currently at version 2.0, defines the calling conventions by which an applet accesses the Java Card run-time environment and native services. This allows applications written for one Java Card-enabled platform to run on any other Java Card-enabled platform.

On a Java Card, applets or 'cardlets' sit on top of the Java VM, which in turn sits on top of the card's operating system. The applets are stored in EEPROM, hence the ability to download new applets and delete unwanted applets during the card's lifetime. This provides great flexibility in that multiple applications can run on a single card, applications can be changed or corrected without having to issue a new card and the time to market for new applications is greatly reduced. The major disadvantage is that the hitherto fixed and tamperproof features of smart cards are now potentially opened up. Malicious applets could be unknowingly loaded, causing increased security concerns. In addition, the speed of execution is a problem for Java-based programs due to the extra layer of activity introduced by the Java VM.

Some Java Card products are currently available or in production, such as Gemplus' GemXpresso, Schlumberger's Cyberflex and Bull's Odyssey, but it could take some time for Java Cards to reach maturity. The Visa Open Platform specification aims to supply extra features, including aspects of security, which are not currently addressed by the Java Card API.

- Multos

An alternative and more mature technology for multi-application smart cards is Multos, promoted by the Maosco consortium [9]. Set up in 1997, this group includes Multos founders Mondex International, among other industry leaders. The Multos specification is more comprehensive than the Java Card specification, defining the physical chip security and operating system as well as the virtual machine and APIs for programming it. Like the Java Card API, Multos is compliant with the ISO 7816 and EMV standards. Applications are again stored in EEPROM but Multos provides a certification scheme for the life cycle of applications — secure downloading, storage and deletion. Multos checks the validity of new applications being downloaded and provides an area of memory in which each can reside. The design of the system provides a logical 'firewall' around each of the applications that will stop any interference between them. Each application is interpreted and talks to external systems via the operating system. This clear separation of applications on the card is vital. Some companies may only be happy having their application added to a multi-application card if they have some confidence that other rival applications on the same card will not interact with it. Maosco claims to be aiming for ITSEC certification level E6 for type-approved Multos cards.

Applications for Multos smart cards can be developed either in a low-level language called MEL (Multos executable language) or in a high-level language such as C. MEL is part of the Multos specification and is a language optimised for 8-bit smart card microprocessors and the Multos-specific security requirements.

Chip manufacturers such as Hitachi, Siemens and Motorola are currently involved in producing Multos approved chips. Multos looks to have strong backing with it being adopted as the technology of choice by MasterCard and American Express. Siemens and Hitachi have opted to put Multos on their (new, but conventional) range of 8-bit crypto-processor smart card ICs, running at the default clock speed of 3.57 MHz, whereas Motorola are producing a range of 32-bit devices, running internally at around 25 MHz,

for Multos. Only practical evaluation will tell which technology gives the optimum combination of performance, reliability and cost.

The advent of these virtual machine, multi-application technologies represents a considerable advance from the days of single application memory cards. Although frequently talked about as a key enabler for smart card applications, it will be interesting to see if we ever reach the era where an individual can hold a single 'white card' to which companies will be happy to add their security, loyalty and payment type applications.

4. Smart card applications in electronic commerce

There are many applications for smart cards in electronic commerce, both existing and proposed. They can typically be categorised into secure access, secure payment, digital signatures and personal utilities. The strongest applications have always been thought to be the first two. It will nevertheless be interesting to see how the adoption of smart cards for desktop computer driven applications, such as the latter two, proceeds.

4.1 Secure access to services

The smart card is capable of providing secure access to a variety of services, independent of delivery channel. Some of the most common uses for smart cards today fall into this category. Satellite television decoder cards are one example, along with SIM (subscriber identity module) cards that authenticate GSM mobile phone users. There are many more besides, particularly as we move into an age of network computing and kiosk type terminals.

A mechanism often employed to ensure that the smart card is being used by its authorised user is known as card holder verification (CHV). Commonly this is achieved by the off-line entry of a PIN known only to the card and its rightful holder. A correct entry will authenticate the card holder, whereas a successive number of incorrect attempts will lock the card (or an application on it) against further attempts. Authentication with a smart card is an example of 'two-factor' authentication, requiring 'something you own' (the smart card) and 'something you know' (the PIN).

Stronger authentication can be achieved from the use of biometric techniques. These can verify a person's identity unambiguously from unique, individual and biological properties. Typically, these fall into either of two categories — physiological features that cannot be consciously altered by the individual, and behavioural features that are subject to some gradual variation. Physiological features may include facial features, retinal and iris patterns [10], fingerprints and hand geometry. Those related to behaviour comprise hand written signatures, writing rhythm, keystroke dynamics and voice characteristics. A smart card

can be used to hold the biometric template of the authorised card holder and depending on the processing power required, has the potential to perform the validation of the user against the template. Biometrics strengthen the authentication process by adding a third factor, namely 'something you are', to 'something you own' and 'something you know'.

The perceived importance of this extra authentication is highlighted in recent trials, such as that being rolled out by the Bank of America [11]. The pilot scheme uses fingerprint recognition to give individuals access to their on-line banking services. To use the system, customers are provided with smart cards holding their on-line banking log-in, PIN and fingerprint template. They then follow a log-in process to access banking information over the Internet, concluding with a scan of their fingerprint using a special scanning device attached to their desktop computer. The fingerprint image from the scanner is compared with the image already stored on the smart card using software. Overall, these mechanisms can provide strong card-holder authentication. In the UK, the Nationwide Building Society recently conducted a successful trial of iris scanning at automatic teller machines (ATMs) in Swindon [12].

Although biometrics will be the way forward to replace the imperfect technology of passwords and PINs, it has yet to enjoy penetration into the mass-market consumer world. This is due to as yet unsolved problems with robustness, enrolment procedures and cost-effectiveness. These problems will no doubt be overcome in the next few years.

Once the card holder has been verified, the card typically needs to authenticate itself to the service application using a card authentication mechanism (CAM). In the case of GSM, this is a cryptographic challenge-response protocol that involves the card creating a cryptographic check variable, signed using its secret key and a signing algorithm. The implication is that only an authentic card could contain the secret key.

After initial access, it can be arranged that third parties can access their own files on a card, with or without user intervention. Secure access services, controlled by the card's operating system, might also make use of personal utilities and digital signatures (such as using secure sockets layer (SSL) client authentication to access Web-based resources), both of which applications are considered in this paper.

4.2 Secure payment

Of the deployments of smart cards likely within the next few years, the market potential of secure payment cards is by far the largest. The technology is being driven by big name players such as Visa and MasterCard. This section considers the use of smart cards as electronic purses and

smart credit/debit cards. The advantages smart cards have to offer are tamper resistance and active processing capabilities, functions that appeal to the financial sector. Currently there are still standards issues to be addressed to encourage the take-up of smart cards.

- Smart credit/debit cards

In 1996, Europay, MasterCard and Visa jointly published a specification called 'IC Card Specifications for Payment Systems' [2]. This specification became known as EMV and covers design aspects for smart cards, terminals and debit/credit applications used in financial transactions. One of the drivers for the move towards smart cards is the ease and low cost with which magnetic stripe credit/debit cards can be forged, causing increasing fraud losses. A measure of the success of EMV is that many smart card products are now advertised as 'EMV-compatible'.

The EMV specifications were designed so that card terminals are not required to contain secure application modules (SAMs) for authenticating cards. This is due to the high cost of managing the worldwide distribution and update of symmetrical keys to partly off-line card terminals. Instead, EMV uses asymmetric techniques to authenticate the card, adopting either static or dynamic data authentication. These are both based on digital signature technology, meaning the terminal will not need to contain any private keys.

Trials of EMV cards have taken place in Northampton and Dunfermline in the UK. Although they may have attracted relatively little usage, the results were good enough to be counted as a 'qualified success', according to the UK Smart Card Club. Outstanding issues include transaction speeds, staff training and the integration of point of sale (POS) terminals. Following this, APACS (Association for Payment Clearing Services) has announced that EMV-compliant chip cards will replace magnetic stripe credit cards in the UK over the course of the next two years. APACS has set the target that, by April 2002, 65% of all credit and debit transactions in the UK will use smart cards.

- SET

SET (secure electronic transactions), a standard sponsored by Visa and MasterCard, provides secure communications across the Internet between the card provider, the holder, the card holder's financial institution, and the merchant's financial institution. There is a general desire to use smart cards in the SET process to improve its security and to provide personal mobility. Smart cards are used to store public key certificates and to generate transaction signatures, as detailed in Putland et al [13]. There are several interesting initiatives currently running, such as

ECOMM and C-SET [14] which are concerned with incorporating the 25 million existing French bank cards into SET, and Chip-SET which hopes to incorporate the existing EMV chip card into SET.

- Electronic purses

The concept of using a smart card as an electronic purse is not new, but it is only just beginning to take off. The idea is simple enough — funds are transferred from a bank account to the card at a terminal and are subsequently transferred from the card to a merchant when used to pay for a variety of products and services. It is a pre-payment scheme, much like telephone cards of today, but greatly superior since payment by electronic purse can be accepted by an unlimited number of merchants unlike the 'closed' telephone card application.

Many of the benefits of electronic purse technology lie at the merchant/bank side as less cash has to be handled, the risk of robbery is reduced and the payment process is faster. Customers reap some reward from potentially faster payment at tills and vending machines (although slow speed was actually a problem at recent trials of Mondex and Visa Cash), and do not have to carry the correct change all the time. There are some interesting downsides for customers though, such as what might happen if they lose their card, or the purse operator goes into liquidation. In addition, they are essentially granting the operator an interest-free loan since they exchange real money for electronic money that they may not spend for a period of time.

- Proton

The Proton scheme is the most successful international electronic purse standard — 30 million such cards have been issued in 15 countries world-wide. A number of national schemes, such as ChipKnip in the Netherlands, use the standard. American Express and Visa both have licences to use it. The Proton specifications are now administered by a profit-making company called Proton World International whose members include Visa, American Express, ERG, Banksys and Interpay.

- Visa Cash

Visa Cash has issued around 21 million cards, although this figure is misleading as it includes their low-security disposable version, which cannot be classed as an international purse technology. It is Visa's policy to badge existing national purse schemes where possible, so the brand includes a variety of purse standards. A large number of trials and pilot schemes have been running in various countries for several years. The nearest thing to the true Visa Cash technology, and the most technologically advanced in the family, has been on trial in Leeds, UK since October 1997. Visa Cash,

Visa debit and Visa credit are all on one card in the UK. A further trial of this technology has just begun in Ennis, Co Clare, Ireland. A joint trial of Visa Cash and Mondex closed after one year at the end of 1998. It was not seen as hugely successful by either retailers or consumers. There was no clear advantage obvious to consumers over existing payment solutions; plus the limited geographic scope of the trial restricted the appeal of holding the card.

- Mondex

Mondex, while being the most technologically advanced, is the smallest by far of the internationally accepted schemes, having issued one million cards. The Swindon pilot scheme, for which BT supplied the home phones, retailer phones and payphones, was concluded recently after running for two years. Volumes on the payphones were quite low, but the home phone was relatively popular with triallists. Trials are also running in Canada and Australia, and there has been a full roll-out in Hong Kong, where it is proving to be a commercial success, being popular with both consumers and retailers.

Mondex is the only purse scheme that emulates real cash, since transactions are not centrally accounted. This property disintermediates some of the stakeholders and makes it difficult for governments to exert fiscal control over the e-cash economy. This has so far prevented Mondex from penetrating the European market to any great degree, outside the UK.

Visa, Proton and a number of European financial institutions have collaborated to create the Common Electronic Purse Specification (CEPS), published in early 1999. This development was spurred on partly by the advent of the new common European currency, the Euro. It is expected that all national purse schemes wishing to have some degree of international interoperability will migrate to CEPS. The Euro/CEPS combination could be the biggest driver for the adoption of electronic cash.

Various small and medium-scale trials of all the above purse schemes have been run to show the viability of electronic cash for making small-value eCommerce payments. The technology works well, especially when combined with user-friendly payment wallets, integrated with Web browsers. The only barriers are the lack of interoperability standards for electronic cash and the lack of infrastructure of smart card readers on eCommerce access devices. The removal of these barriers is imminent, with the arrival of PC/SC and Smart Cards for Windows, as discussed earlier in this paper. These barriers do not apply to the use of e-purses with GSM equipment and Cellnet is currently gearing up for a trial of loading value on to Mondex cards over GSM, i.e. a mobile ATM.

It is widely accepted that there is no short-term business case for electronic cash in high street transactions. Deployment, therefore, has to be looked at from a perspective of long-term protection of one's business. Financial card issuers will therefore slowly deploy the electronic purse on the back of other applications, the business model for which has not been fully developed. Electronic cash will add value to the eCommerce world, but since eCommerce currently represents only a tiny fraction of the world's cash economy, benefits for institutions are currently small. Again, progress is slow, but could then explode as standardised purse schemes and interfaces to PCs come on to the market.

4.3 *Smart cards for digital signatures*

An emerging role for smart cards lies in their application to digital signature schemes. This section focuses on smart cards in a public-key infrastructure (PKI) and discusses how they can contribute end-to-end security and portability. Electronic commerce transactions will be dependent upon trust between a buyer and seller, parties who may only have met in the 'electronic world'. There is a requirement for the transacting parties to be able to authenticate each other, check one another's credentials and guarantee the integrity of messages passing between them. This is achievable using digital signatures and certificates, concepts that are described extensively elsewhere [15, 16] and hence are not presented in any more detail here. The value of a digital signature depends upon the signer protecting their private key against misuse by another party.

Currently, many users of public-key cryptography store their private keys on their desktop computers. This private key database tends to take the form of an encrypted file on the hard drive, with access being controlled by a single password. There are many risks associated with this practice. How well the keys are protected ultimately depends on the strength of the password chosen by the user. This password will most likely have been used to generate another key to encrypt the user's private keys. A brute force 'dictionary' type attack on this password may be possible, simplified if there is any known plaintext in the private key file. The default locations of private key files are often known in common packages such as Web browsers. Access to a user's computer, by physical presence or over a network, needs to be carefully controlled. Also, during operations such as generating a digital signature, the computer program will need access to the user's private keys. The file storing them will be opened and the keys decrypted, upon presentation of the correct password. The private keys are thus going to be temporarily held in memory and perhaps even saved to a swap file, according to the virtual memory settings, where they are at risk. This is dependent upon the computer operating system in use, but is an example of exploiting security flaws in the operating system to divulge information.

Smart cards can be used to address these security weaknesses, with varying degrees of improvement that can be chosen to match the trade-off between perceived risk and cost. Security is of paramount importance in the design of an operating system for smart cards, something that is not always the case for desktop computers. The first generation digital signature cards simply provide secure private key storage. The card still relies on some form of PIN or password authentication but is designed to be more tamper resistant, both physically and by dedicated software. While this results in a secure and portable storage medium for private keys, the cryptographic processing is still provided by the host computer, hence private keys are still read from the smart card for operations such as digitally signing and decrypting messages.

The second generation cards can perform the cryptographic operations internally. In addition to a microprocessor, these cards have a hardware cryptographic co-processor within the chip. This co-processor speeds up the operation of the mathematical functions required to perform encryption algorithms that are otherwise unacceptably slow when performed by software alone within a smart card. This ensures that private keys can remain within the secure environment of the smart card rather than having to enter the memory of the computer for processing. Some newer cards are capable of generating cryptographic key pairs on-board, thus enabling the whole life cycle of the private key to be managed within the card. Such developments are essential if evidence based on the use of digital signatures is to be strong enough to stand up in a court of law. In such a card, it is essential that security is

implemented in the application, the operating system and the card's physical structure.

The German digital signature law [17], passed in 1997, defines the responsibilities of a licensed certification authority and lists some technical requirements for components used to generate digital signatures. It talks of a 'data storage medium' for the private key, which although left generic, is by implication a smart card. Biometrics for identifying the key holder are also discussed.

Even with a cryptographic co-processor within the smart card chip, the speed of execution of the different signature algorithms, which also varies with different key sizes, is an issue. The data transfer rate between the host system and the smart card is also a concern, especially with large amounts of data.

To reduce the time taken to process such large quantities of data through public-key cryptography algorithms within the smart card, and to reduce the transfer time into and out of the smart card, the data can be reduced to a minimum, predictable size. This is seen in the processes of generating a digital signature and decrypting session keys used to encrypt documents, both examples of operations requiring the user's private keys and hence best carried out on a smart card.

In the case of the generation of a digital signature, the hash function that manipulates the entire document to produce a small, fixed-size message digest or 'hash', can be performed on the host computer system, as shown in Fig 3.

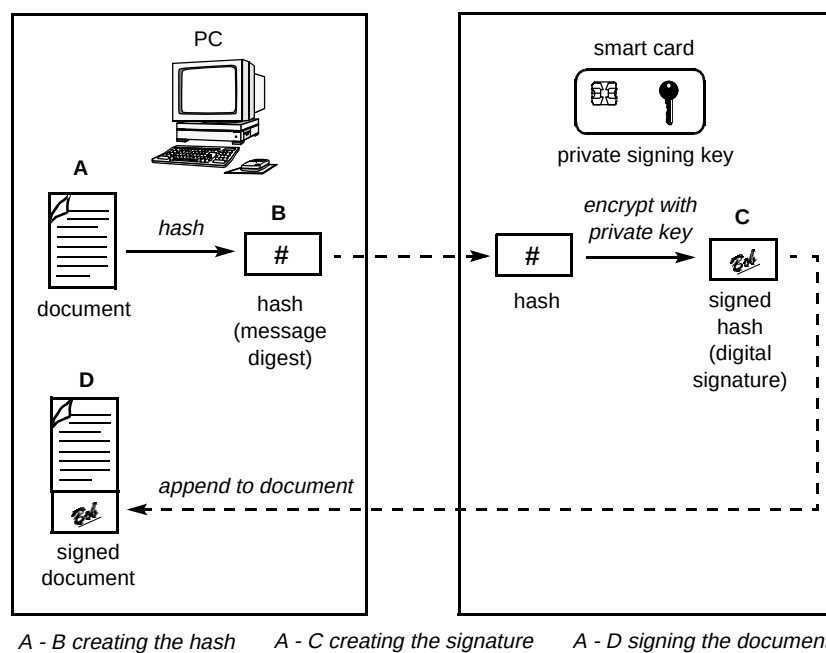


Fig 3 Signing a document using a smart card to generate the digital signature.

The hash can then be passed to the smart card for encryption with the user's private signing key to produce the digital signature. This is then returned to the host computer, appended to the document and forwarded to the recipient. The only data that needs to be loaded on to the smart card in this instance is the hash, which may be only 128 bits (MD2/4/5 hash algorithms) or 160 bits (SHA) long, depending upon the particular scheme in use. The next generation of cards, required for Multos and for applications using Common Electronic Purse Specifications, will be able to perform all these operations on the card itself.

Many of the leading chip manufacturers have been working to develop fast cryptographic co-processors over the past two years or so. The RSA and DSA public-key cryptography algorithms are those typically supported, with manufacturers also looking to exploit elliptic curve algorithms on smart cards due to the lower key lengths employed for a comparable level of security. The state-of-the-art chips at present perform 1024-bit RSA signatures in less than one second [18]. Each architecture tends to employ various optimisations for speeding up the cryptographic computations.

Commercial products are currently emerging that allow digital signatures to be generated by smart cards — the Netscape and Microsoft version 4.X Web browsers are examples. However, smart card integration is being delayed by immature technology and conflicting standards as detailed earlier.

Widespread deployment is unlikely until a single, multi-application smart card is available that not only generates digital signatures, but supports other common desktop requirements such as secure log-on and remote access as well. Microsoft's Smart Cards for Windows could well fulfil this requirement.

4.4 Personal utilities

There are a number of personal utilities relating to electronic commerce which users would find beneficial when stored on a smart card. These include secure 'counter' utilities, such as loyalty points storage, as well as data file storage. Files could be unprotected, containing perhaps a desktop user's bookmarks, personal e-mail address book and preferences, or protected, holding information such as personal account numbers and health details.

The smart card has long been established as a useful carrier for such items. Its principal benefits are mobility, given that the data on the card can be used in any terminal with the appropriate interface, and security, with access individually specified for each file or group of files on the card.

5. Conclusions

It is commonly accepted that smart cards will play an important part in electronic commerce. Smart cards are a vehicle for meeting the end-to-end security and mobility requirements of many applications in this field. We have highlighted such deployments as secure access, payment, and digital signature cards, earmarked as key drivers of smart card technology. The recent changes in technology have been examined, concerning standardising smart card peripherals, making application design easier for the developer and reducing the time-scales for new mass deployments.

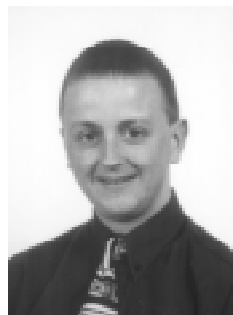
It is unlikely that the end user will have just one smart card in his wallet within the space of a year or two. It is still likely to be a collection of cards. Technology is not the only barrier to this convenience. The power of branding smart cards is not to be underestimated. Even if the card's function is not all that smart, customers are holding and brandishing pieces of plastic bearing a corporate logo.

If multi-application cards are to become the norm in the new millennium then a scheme such as Multos looks to be the most applicable. Multos addresses the main card security concerns by providing a scheme for the secure loading and unloading of applications. It also addresses any potential adverse interaction by isolating applications on the card. The arrival of Microsoft on the scene (with PS/SC, Smart Cards for Windows and the latest browsers and operating systems) will surely have a fundamental effect upon the take-up of smart cards by the eCommerce world.

References

- 1 ISO 7816 Identification Cards — Integrated circuit(s) cards with contacts Part 1: Physical characteristics, <http://www.iso.ch/cate/d29257.html> Part 2: Dimensions and location of the contacts, <http://www.iso.ch/cate/d26536.html> Part 3: Electronic signals and transmission protocols, <http://www.iso.ch/cate/d14735.html>
- 2 EMV — <http://www.mastercard.com/emv/>
- 3 GSM — <http://www.etsi.fr/smg/>
- 4 PC/SC — <http://www.smartcardsys.com/>
- 5 CryptoAPI — <http://www.microsoft.com/security/tech/cryptoapi/>
- 6 Cryptoki — <http://www.rsa.com/rsalabs/pubs/PKCS/html/pkcs-11.html>
- 7 Smart Cards for Windows — <http://www.microsoft.com/windowsce/smartcard/>
- 8 Java Card — <http://www.javasoft.com/> and <http://java.sun.com/products/javacard/>
- 9 Multos — <http://www.multos.com/>
- 10 Gifford M M, McCartney D J and Seal C H: 'Networked biometrics systems — requirements based on iris recognition', *BT Technol J*, 17, No 2, pp 163—169 (April 1999).

- 11 Bank of America biometrics trial from InternetNews.com — <http://www.internetnews.com/ec-news/1999/01/0601-bank.html>
- 12 'Iris recognition wins Nationwide approval', Fraudwatch magazine, 6, Issue 6 (1998).
- 13 Putland P A, Ward C, Jackson A and Trollope C: 'Electronic payment systems', BT Technol J, 17, No 3, pp 57—66 (July 1999).
- 14 C-SET, Chip-SET — http://www.europay.com/E_commerce/html/Index_commerce.html
- 15 Phoenix S J D: 'Cryptography, trusted third parties and escrow', BT Technol J, 15, No 2, pp 45—62 (April 1997).
- 16 Skevington P J and Hart T P: 'Trusted third parties in electronic commerce', BT Technol J, 15, No 2, pp 39—44 (April 1997).
- 17 German Digital Signature Ordinance — <http://www.iid.de/iukdg/sigve.html>
- 18 Handshuh H and Paillier P: 'Smart card crypto-coprocessors for public key cryptography', Cryptobytes — the technical newsletter of RSA Laboratories (Summer 1998).



Neil Trask joined BT in 1996 after gaining an MEng in Electronic Systems Engineering at the University of York.

He is working in the Advanced Communications Research Security Laboratory, looking at public-key infrastructures and smart cards.

He is an associate member of the IEE.



Mike Meyerstein received his honours degree in Mechanical Engineering Science from the University of Liverpool in 1971. After a varied international career including seven years in the Canadian telecommunications industry, he joined BT Laboratories in 1985. After spending 5 years working on innovations in electronic packaging, he became BT's technical adviser for smart cards in early 1991. Since then he has worked on projects including Phoncard, Mondex and the BT Smart Card Platform.